institution's customer information, including notification to the institution as soon as possible of any such incident, to enable the institution to expeditiously implement its response program.[611]

The Banking Agencies' Safeguards Guidance requires certain financial institutions to implement a comprehensive written information security program that includes administrative, technical, and physical safeguards appropriate to the size and complexity of the entity and the nature and scope of its activities.[612] This guidance requires that the information security program be designed to (1) ensure the security and confidentiality of customer information; (2) protect against any anticipated threats or hazards to the security or integrity of such information; (3) protect against unauthorized access to or use of such information that could result in substantial harm or inconvenience to any customer; and (4) ensure the proper disposal of customer information and consumer information.[613]

Private funds may be subject to the FTC's recently amended FTC Safeguards Rule, which contains data security requirements to protect customer financial information.[614] The FTC Safeguards Rule generally requires financial institutions to develop, implement, and maintain a comprehensive information security program,[615] defined as the administrative, technical, and physical safeguards the financial institution uses to access, collect, distribute, process, protect, store, use, transmit, dispose of, or otherwise handle customer information.[616] The rule also

---

611 *See id.*, at Supplement A, section II.

612 *See* Banking Agencies' Safeguards Guidance, at section II.A.

613 *See id.*, at section II.B.

614 The FTC Safeguards Rule applies to financial institutions of certain types "that are not otherwise subject to the enforcement authority of another regulator under section 505 of the Gramm-Leach-Bliley Act, 15 U.S.C. 6805." *See* 16 CFR 314.1(b). Private funds that are able to rely on section 3(c)(1) or 3(c)(7) of the Investment Company Act are not subject to Regulation S-P but they may be subject to the FTC Safeguards Rule. *See supra* footnote 2. Investment advisers registered with the Commission, including those that are advisers to private funds, are covered institutions for the purposes of the final amendments.

615 *See* 16 CFR 314.3(a).

616 *See* 16 CFR 314.2(i).

requires that the comprehensive information security program contain various elements, including an incident response plan.[617] In addition, it requires financial institutions to take reasonable steps to select and retain service providers capable of maintaining appropriate safeguards for customer information and to require those service providers by contract to implement and maintain such safeguards.[618] Since the date of our proposal, the FTC Safeguards Rule has been updated to require financial institutions to notify the FTC as soon as possible, and no later than 30 days after discovery, of a security breach involving the unencrypted information of at least 500 consumers.[619] Although the FTC Safeguards Rule does not contain a customer notification requirement, the FTC indicated that it "intends to enter notification event reports into a publicly available database" unless a law enforcement official requests delay.[620]

In addition, many entities covered by this rule may be subject to other, more general information protection requirements.[621] In particular, companies operating in foreign jurisdictions may need to comply with information protection requirements in their foreign markets. For example, the GDPR requires entities that process the personal data of EU citizens or residents to, among other things, do so in a manner that ensures appropriate security, integrity, and

---

617 *See* 16 CFR 314.4(h).

618 *See* 16 CFR 314.4(f). The FTC Safeguards Rule does not contain a requirement that financial institutions require their service providers to notify them in case of a breach resulting in customer information being compromised.

619 The amendments are effective May 13, 2024. *See Standards for Safeguarding Customer Information*, 88 FR 77499 (Nov. 13, 2023); *see also* FTC Press Release, *FTC Amends Safeguards Rule to Require Non-Banking Financial Institutions to Report Data Security Breaches* (Oct. 27, 2023), *available at* https://www.ftc.gov/news-events/news/press-releases/2023/10/ftc-amends-safeguards-rule-require-non-banking-financial-institutions-report-data-security-breaches.

620 88 FR at 77506. *See also* 16 CFR 315.4(j)(vi) (effective May 13, 2024), describing the conditions for a delay in notifying the public of the breach, if requested by law enforcement.

621 *See supra* Section I (discussing other requirements); footnotes 245, 257 (examples of other regimes); *see also* Microsoft Comment Letter.

confidentiality.[622] Other recent regulations in foreign jurisdictions may subject covered institutions to further rules intended to address cybersecurity risk management by financial institutions and some of their service providers.[623] Hence, we expect that some of the entities covered by the final amendments, or their service providers, already have customer information safeguards in place because of other information protection regimes.

A variety of guidance is available to institutions seeking to address information security risk, particularly through the development of policies and procedures. These include NIST and CISA voluntary standards, both of which include assessment, containment, and notification elements similar to those included in these amendments.[624] We do not have extensive data spanning all types of covered institutions on their use of these or similar guidelines or on their development of written policies and procedures to address incident response, and no commenter suggested such data. However, past Commission examination sweeps of broker-dealers and investment advisers suggest that such practices are widespread.[625] Thus, we expect that

---

622 GDPR, *supra* footnote 245, at Art. 5(1)(f); *see also What is GDPR, the EU's New Data Protection Law?*, *available at* https://gdpr.eu/what-is-gdpr/ (last visited Apr. 8, 2024). The GDPR places data protection obligations on organizations that process the personal data of EU citizens and residents. Among these are provisions requiring notification in the case of a breach: Art. 34(1), for example, requires a personal data breach to be "communicated to the data subject without undue delay" when the breach is likely to result in a high risk to the rights and freedoms of natural persons, unless certain exceptions (including an encryption exception) apply.

623 *See, e.g.*, *Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on Digital Operational Resilience for the Financial Sector and Amending Regulations*, OFFICIAL J. OF THE EURO. UNION (2022), *available at* https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX:32022R2554 ("DORA").

624 *See* NIST Special Publication 800-61, Revision 2 (Aug. 2012) ("NIST Computer Security Incident Handling Guide"), *available at* https://csrc.nist.gov/publications/detail/sp/800-61/rev-2/final and CISA, Cybersecurity Incident & Vulnerability Response Playbooks (Nov. 2021) ("CISA Incident Response Playbook"), *available at* https://www.cisa.gov/sites/default/files/publications/Federal_Government_Cybersecurity_Incident_and_Vulnerability_Response_Playbooks_508C.pdf.

625 *See* OCIE, SEC, *Cybersecurity Examination Sweep Summary* (Feb. 3, 2015), *available at* https://www.sec.gov/about/offices/ocie/cybersecurity-examination-sweep-summary.pdf (Written policies and procedures, for both the examined broker-dealers (82%) and the examined advisers (51%), discuss mitigating the effects of a cybersecurity incident and/or outline the plan to recover from such an incident.

institutions seeking to develop written policies and procedures likely would have encountered these and similar standards and may have included the critical elements of assessment and containment, as well as notification.

c. Annual Notice Delivery Requirement

Under the baseline,[626] a broker-dealer, funding portal, investment company, or registered investment adviser must generally provide an initial privacy notice to its customers not later than when the institution establishes the customer relationship and annually after that for as long as the customer relationship continues.[627] If an institution chooses to share nonpublic personal information with a nonaffiliated third party other than as disclosed in an initial privacy notice, the institution must generally send a revised privacy notice to its customers.[628]

The types of information required to be included in the initial, annual, and revised privacy notices are identical. Each privacy notice must describe the categories of information the institution shares and the categories of affiliates and non-affiliates with which it shares nonpublic personal information.[629] The privacy notices also must describe the type of information the institution collects, how it protects the confidentiality and security of nonpublic personal

---

Similarly, most of the examined broker-dealers (88%) and many of the examined advisers (53%) reference published cybersecurity risk management standards.).

626 For the purposes of the economic analysis, the baseline does not include the exception to the annual notice delivery requirement provided by the FAST Act. This statutory exception was self-effectuating and became effective on Dec. 4, 2015. *See* FAST Act, Pub. L. 114-94, § 75001, adding section 503(f) to the GLBA, codified at 15 U.S.C. 6803(f).

627 17 CFR 248.4 and 248.5.

628 17 CFR 248.8. Regulation S-P provides certain exceptions to the requirement for a revised privacy notice, including if the institution is sharing as permitted under rules 248.13, 248.14, and 248.15 or with a new nonaffiliated third party that was adequately disclosed in the prior privacy notice.

629 *See* 17 CFR 248.6(a)(2) through (5) and 248.6(a)(9).

information, a description of any opt out right, and certain disclosures the institution makes under the FCRA.[630]

3. Market Structure

The final amendments will affect five categories of covered institutions: broker-dealers other than notice-registered broker-dealers, funding portals, registered investment advisers, investment companies, and transfer agents registered with the Commission or another appropriate regulatory agency. These institutions compete in several distinct markets and offer a wide range of services, including effecting customers' securities transactions, providing liquidity, pooling investments, transferring ownership in securities, advising on financial matters, managing portfolios, and consulting to pension funds. Many of the larger covered institutions belong to more than one category (e.g., a dually registered broker-dealer / investment adviser), and thus operate in multiple markets. In the rest of this section, we first outline the market for each class of covered institution and then consider service providers.

a. Broker-Dealers

Broker-dealers include both brokers (persons engaged in the business of effecting transactions in securities for the account of others),[631] as well as dealers (persons engaged in the business of buying and selling securities for their own accounts).[632] Most brokers and dealers maintain customer relationships, and are thus likely to come into the possession of sensitive

---

630 *See* 17 CFR 248.6(a)(1) (information collection); 248.6(a)(8) (protecting nonpublic personal information), 248.6(a)(6) (opt out rights); 248.6(a)(7) (disclosures the institution makes under section 603(d)(2)(A)(iii) of the FCRA (15 U.S.C. 1681a(d)(2)(A)(iii)), notices regarding the ability to opt out of disclosures of information among affiliates).

631 *See* 15 U.S.C. 78c(a)(4).

632 *See* 15 U.S.C. 78c(a)(5).

customer information.[633] In the market for broker-dealer services, a relatively small set of large- and medium-sized broker-dealers dominate while thousands of smaller broker-dealers compete in niche or regional segments of the market.[634] Broker-dealers provide a variety of services related to the securities business, including (1) managing orders for customers and routing them to various trading venues; (2) providing advice to customers that is in connection with and reasonably related to their primary business of effecting securities transactions; (3) holding customers' funds and securities; (4) handling clearance and settlement of trades; (5) intermediating between customers and carrying/clearing brokers; (6) dealing in corporate debt and equities, government bonds, and municipal bonds, among other securities; (7) privately placing securities; and (8) effecting transactions in mutual funds that involve transferring funds directly to the issuer. Some broker-dealers may specialize in just one narrowly defined service, while others may provide a wide variety of services.

Based on an analysis of FOCUS filings and Form BD filings, there were 3,476 registered broker-dealers during the third quarter of 2023.[635] Of these, 303 were dually registered as investment advisers.[636] There were over 233 million customer accounts reported by carrying brokers.[637] However, the majority of broker-dealers are not "carrying broker-dealers" and

---

633 Such information would include the customers' names, tax numbers, telephone numbers, broker, brokerage account numbers, etc.

634 *See* Regulation Best Interest: The Broker-Dealer Standard of Conduct, Release No. 34-86031 (June 5, 2019) [84 FR 33318 (July 12, 2019)], at 33406.

635 The numbers in this section exclude notice-registered broker-dealers. *See supra* section II.B.3.

636 *See supra* footnote 496.

637 FOCUS filings and Form X-17A-5 Schedule I, Item I8080. For this release, the number of customer accounts reported by carrying brokers was estimated based on FOCUS filings during the third quarter of 2023 and Form X-17A-5 Schedule I, Item I8080 for 2022. The Proposing Release cited a figure of 72 million as of July 1, 2022. The correct number of customer accounts reported by carrying brokers as of July 1, 2022, in the Proposing Release should be 220 million. This change would not have affected the Commission's assessment of economic effects at Proposal as these assessments were focused primarily on effects at the level of individual covered institutions and their customers.

therefore do not report the numbers of customer accounts.[638] Therefore, we expect that this figure of 233 million understates the total number of customer accounts because many of the accounts at carrying broker-dealers have corresponding accounts with non-carrying brokers. Both carrying and non-carrying broker-dealers potentially possess sensitive customer information for the accounts that they maintain.[639] Because non-carrying broker-dealers do not report on the numbers of customer accounts, it is not possible to ascertain with any degree of confidence the distribution of customer accounts across the broader broker-dealer population.

b. Funding Portals

Funding portals act as intermediaries in facilitating securities-based crowdfunding transactions that are subject to Regulation Crowdfunding.[640] Securities-based crowdfunding involves using the Internet to raise capital through small individual contributions from a large number of people. The crowdfunding transaction must be conducted through an intermediary registered with the Commission, but a statutory exemption allows that intermediary to forgo registration as a broker-dealer. Therefore some, but not all, crowdfunding intermediaries are registered broker-dealers while others are funding portals.

Funding portals are registered with the Commission and are members of FINRA.[641] They must provide investors with educational materials, take measures to reduce the risk of fraud,

---

638 *See* General Instructions to Form CUSTODY (as of Sept. 30, 2022).

639 This information includes name, address, age, and tax identification or Social Security number. *See* FINRA Rule 4512.

640 *See* 17 CFR part 227.

641 *See* Regulation Crowdfunding, Release No. 33-9974, (Oct. 30, 2015) [80 FR 71388 (Nov. 16, 2015)] ("Regulation Crowdfunding Adopting Release"). An entity raising funds through securities-based crowdfunding typically seeks small individual contributions from a large number of people. Individuals interested in the crowdfunding campaign—members of the "crowd"—may share information about the project, cause, idea or business with each other and use the information to decide whether to fund the campaign based on the collective "wisdom of the crowd." The JOBS Act established a regulatory structure for startups and small businesses to raise capital through securities offerings using the Internet through

make information available about the issuer and the offering, and provide communication channels to permit discussions about offerings on the funding portal's platform, among other related services.[642] In facilitating crowdfunding transactions, funding portals may come into possession of investors' sensitive customer information, as investors are required to open an account with the funding portal before the funding portal may accept an investment commitment from them.[643] Funding portals may have possession of sensitive customer information but, unlike broker-dealers, funding portals are statutorily prohibited from holding, managing, possessing, or handling investor funds or securities.[644] These funding portals are required to direct investors to transmit money or other consideration for the securities directly to a qualified third party that has agreed in writing to hold the funds for the benefit of investors and the issuer and to promptly transmit or return the funds to the person entitled to the funds.[645]

As of December 31, 2023, there were 92 registered funding portals that were members of FINRA (excluding funding portals that had withdrawn their registration and FINRA

---

crowdfunding. *See id*. at section I.A. Securities Act section 4(a)(6) provides an exemption from registration for certain crowdfunding transactions. 15 U.S.C. 77d(a)(6). A company issuing securities in reliance on rules established by the Regulation Crowdfunding Adopting Release (17 CFR part 227, "Regulation Crowdfunding") is permitted to raise a maximum of $5 million in a twelve-month period and is required to conduct the transaction exclusively through an intermediary registered with the Commission, either a broker-dealer or a funding portal. *See* 17 CFR 227.100(a).

642 *See* Regulation Crowdfunding Adopting Release at section II.

643 *See* 17 CFR 227.302(a)(1). Regulation Crowdfunding Rule 302 does not prescribe specific information that a funding portal must collect as part of opening an account.

644 *See* 15 U.S.C. § 78c(a)(80)(D).

645 *See* 17 CFR 227.303(e)(2), which defines a "qualified third party" as (i) a registered broker or dealer that carries customer or broker or dealer accounts and holds funds or securities for those persons or (ii) a bank or credit union (where such credit union is insured by National Credit Union Administration) that has agreed in writing either to hold the funds in escrow for the persons who have the beneficial interests therein and to transmit or return such funds directly to the persons entitled thereto when so directed by the funding portal as described in paragraph (e)(3) of the rule, or to maintain a bank or credit union account (or accounts) for the exclusive benefit of investors and the issuer.

membership).[646] The crowdfunding intermediary market is highly concentrated.[647] For example, based on staff analysis from May 16, 2016 (inception of Regulation Crowdfunding) through December 31, 2023, five intermediaries accounted for 70 percent of all initiated offerings, including one funding portal accounting for 29 percent of all initiated offerings.[648]

c. Investment Advisers

Registered investment advisers provide a variety of services to their clients, including financial planning advice, portfolio management, pension consulting, selecting other advisers, publication of periodicals and newsletters, security rating and pricing, market timing, and conducting educational seminars.[649] Although advisers engaged in any of these activities are likely to possess sensitive customer information, the degree of sensitivity will vary widely across advisers. Some advisers may only hold the customer's address, payment details, and the customer's overall financial condition, while others may hold account numbers, tax identification numbers, access credentials to brokerage accounts, and other highly sensitive information.

Based on Form ADV filings received up to October 5, 2023, there are 15,565 investment advisers registered with the Commission with a total of more than 51 million individual clients and $114 trillion in assets under management.[650] Practically all (97 percent) of these advisers reported providing portfolio management services to their clients.[651] Over half (57 percent)

---

646 *See* FINRA, "Funding Portals We Regulate," at https://www.finra.org/about/funding-portals-we-regulate.

647 The crowdfunding intermediary market includes all funding portals and some registered broker-dealers who may also serve as intermediaries of Regulation Crowdfunding transactions. *See* 17 CFR 227.300(a).

648 Based on staff analysis of EDGAR filings under Regulation Crowdfunding as of December 31, 2023. This includes all initiated offerings facilitated by either funding portals or registered broker-dealers.

649 *See* Form ADV.

650 Form ADV, Items 5D(a-b) (as of Oct. 5, 2023). Broadly, regulatory assets under management capture the current value of assets in securities portfolios for which the adviser provides continuous and regular supervisory or management services. *See* Form ADV, Part 1A Instruction 5.b.

651 Form ADV, Items 5G(2-5) (as of Oct. 5, 2023).

reported having custody of clients' cash or securities either directly or through a related person,[652] with client funds in custody totaling $43 trillion.[653]

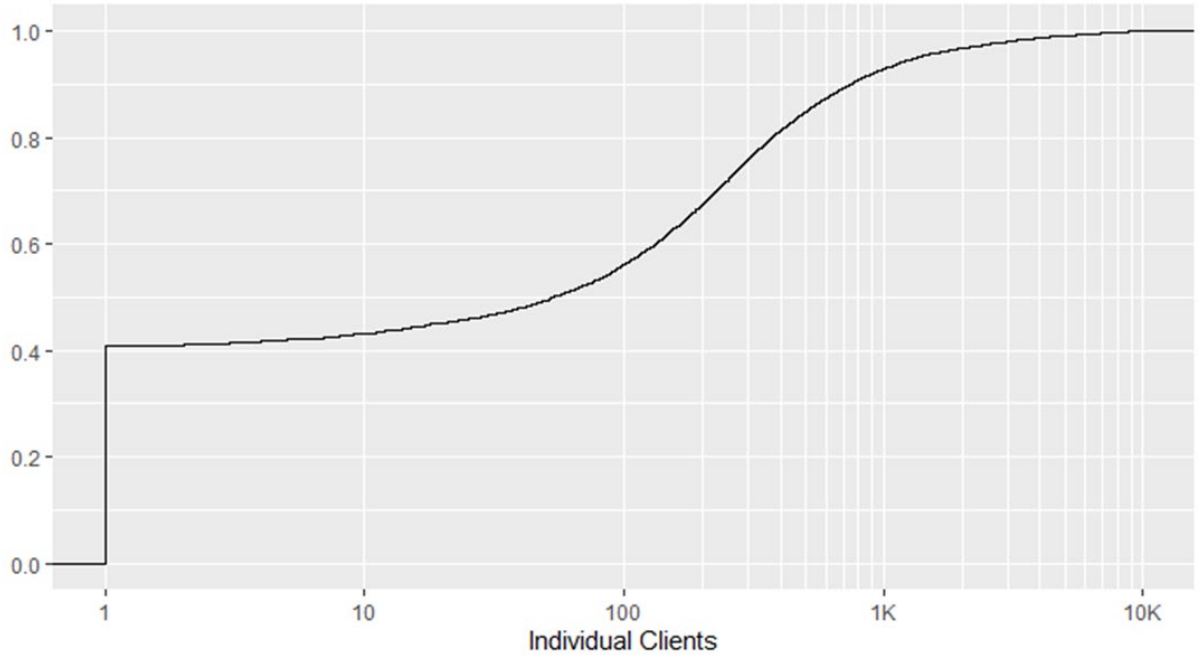

Figure 6: Cumulative distribution of the number of clients across investment advisers. Data source: Form ADV, Items 5D(a-b) (as of Oct. 5, 2023).

Figure 6 plots the cumulative distribution of the number of individual clients handled by investment advisers registered with the Commission. The distribution is highly skewed: 13 advisers each reported having more than one million clients while 95 percent of advisers reported having fewer than 2,000 clients. Many such advisers are quite small, with half reporting fewer than 62 clients.[654]

652 Here, "custody" means "holding, directly or indirectly, client funds or securities, or having any authority to obtain possession of them." An adviser also has "custody" if "a related person holds, directly or indirectly, client funds or securities, or has any authority to obtain possession of them, in connection with advisory services [the adviser] provide[s] to clients." *See* 17 CFR 275.206(4)-2(d)(2).

653 Form ADV, Items 9A and 9B (as of Oct. 5, 2023).

654 Form ADV, Items 5D(a) and (b) (as of Oct. 5, 2023).